

Security+ 4.6 · Identity & Access Management

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.6** — Identity & Access Management (12:46) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: IAM encompasses account provisioning (create/configure), RBAC (role-based) and ABAC (attribute-based), SSO (federated single sign-on — SAML/OIDC), and service accounts (script credentials — special management).

High-Yield Core Concepts Tested on Exam

- RBAC by role; ABAC by attribute — two authorization methods
- SSO: single login — reduces password reuse (more secure)
- Account provisioning: create and configure accounts
- Service accounts require special credential management
- SSO often uses SAML or OIDC

Exam Tips & Classic Scenarios

- 'access assigned based on job role' = RBAC

Typical Exam Scenario: A marketing employee can only access files in the marketing department. This is an example of RBAC.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.6 — Identity & Access Management)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **TACACS+:** Terminal Access Controller Access-Control System Plus: Enterprise AAA protocol running over TCP port 49; fully encrypts the entire packet payload and decouples authentication from authorization, enabling granular per-command control on network switches and routers.
- **RADIUS:** Remote Authentication Dial-In User Service: Client/server AAA protocol (UDP ports 1812/1813) standard in 802.1X and VPN environments; encrypts only the password field and combines authentication and authorization.
- **KERBEROS:** Default Active Directory authentication protocol based on symmetric ticket granting issued by the Key Distribution Center (KDC: AS and TGS), preventing cleartext credentials on the wire.
- **LDAP:** Lightweight Directory Access Protocol: Protocol for querying centralized directory services (cleartext over TCP port 389).
- **RBAC:** Role-Based Access Control: Access model granting permissions based on organizational job roles rather than individual user identities.
- **ABAC:** Attribute-Based Access Control: Dynamic access control model evaluating user, resource, action, and contextual environment attributes (time, device posture, location).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. MFA combines factors from different categories. Which trio represents the 3 categories?

- A)** Password, PIN, and secret answer
- B)** Something you know, something you have, something you are
- C)** 3 different passwords
- D)** Username, password, and email

2. The service that controls WHO can access WHAT in the cloud (users, roles, permissions) is:

- A)** CDN
- B)** IAM
- C)** VPN
- D)** DNS

3. Which authentication protocol uses tickets and is widely used in Active Directory environments?

- A)** RADIUS
- B)** TACACS+
- C)** Kerberos
- D)** LDAP

4. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'RBAC by ROLE; ABAC by attribute — the two ways to authorize.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RBAC by ROLE; ABAC by attribute — the two ways to authorize...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'SSO: single login — reduces password reuse (more secure).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: SSO: single login — reduces password reuse (more secure).

6. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'access assigned based on job role'=RBAC'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'access assigned based on job role'=RBAC...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'marketing employee only accesses marketing department files' = RBAC. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'marketing employee only accesses marketing department files' = RBAC...
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'RBAC by ROLE; ABAC by attribute — the two ways to authorize'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: RBAC by ROLE; ABAC by attribute — the two ways to authorize...

9. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'SSO: single login — reduces password reuse (more secure)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: SSO: single login — reduces password reuse (more secure)...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Identity & Access Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'access assigned based on job role'=RBAC'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'access assigned based on job role'=RBAC...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Something you know, something you have, something you are.

✅ **Why it's correct:** Multi-factor authentication (MFA) requires combining at least two factors from distinct categories. The three classic categories are: something you know (knowledge, such as a password or PIN), something you have (possession, such as a physical token or code-generating app), and something you are (inherence, such as a fingerprint or facial recognition). The option 'Something you know, something you have, something you are' is the only one that correctly lists these three categories, as defined by NIST SP 800-63 and CompTIA Security+ SY0-701. MFA is an access control that mitigates credential compromise risks, as an attacker would need to overcome multiple independent barriers.

❌ **Why the others are wrong:**

- *Password, PIN, and secret answer:* Password, PIN, and secret answer are all examples of 'something you know' (knowledge factor). Although they are authentication mechanisms, they belong to the same category, so they do not constitute true MFA. Using multiple secrets of the same type is called multi-step authentication or apparent multifactor, but it does not meet the requirement of distinct categories. Additionally, secret answers are often vulnerable to social engineering attacks and can be discovered, not offering the same level of security as a second factor from a different category.
- *3 different passwords:* Three different passwords are still only a knowledge factor. Repeating passwords does not add a new authentication category; it only increases complexity within the same category. This is not MFA, because an attacker who compromises the password capture mechanism (e.g., keylogger or phishing) can obtain all three. Security is not multiplied by the number of passwords, but by the diversity of factors. CompTIA Security+ emphasizes that MFA requires factors of different types, not multiple instances of the same type.
- *Username, password, and email:* Username and email are identifiers, not authentication factors. The username and email address are public or easily discovered and do not prove identity. The password is a knowledge factor, but the other two are not authentication factors. Therefore, this combination does not represent MFA. Additionally, email can be used as a channel for sending codes, but by itself it is not a factor; it is a transport medium. The formal definition of MFA requires each factor to be from a different category (knowledge, possession, inherence), and here there is only one real factor.

2) B — IAM.

✅ **Why it is correct:** IAM (Identity and Access Management) is the service that manages identities, authentication, and authorization in the cloud. It controls WHO can access WHAT by defining users, groups, roles, permission policies, and access conditions. In the CompTIA Security+ SY0-701 syllabus, IAM is presented as the pillar for applying the principle of least privilege, separation of duties, and multifactor authentication. Services like AWS IAM, Azure AD (Entra ID), and Google Cloud IAM allow creating granular policies that specify allowed or denied actions on specific resources, making it the exact answer for cloud access control.

❌ **Why the others are wrong:**

- *CDN:* CDN (Content Delivery Network) is a geographically distributed network of servers to deliver static and dynamic content with low latency, such as images, videos, and files. It improves performance and availability but does not manage identities, roles, or permissions. It does not control who accesses what; it only optimizes content delivery. Therefore, it is completely inapplicable to the logical access control problem described in the question.
- *VPN:* VPN (Virtual Private Network) establishes an encrypted tunnel to protect communication

between a device and a network, ensuring confidentiality and integrity of traffic. Although it can be used as part of a secure remote access strategy, it does not define who can access which resources in the cloud. The VPN authenticates the tunnel but does not manage granular permissions on services and data. Access control to specific resources is the function of IAM, not VPN.

- **DNS:** DNS (Domain Name System) translates domain names into IP addresses, enabling the location of services on the internet. It is fundamental for name resolution but has no relation to authentication, authorization, or identity management. It does not control who accesses what; it only resolves names. Confusing DNS with IAM is a categorical error, as they operate at completely different layers of the OSI and security models.

3) C — Kerberos.

✓ **Why it's correct:** **Kerberos** is a ticket-based authentication protocol widely used in Microsoft Active Directory (AD) environments. It uses symmetric cryptography and a Key Distribution Center (KDC) to authenticate users and services without transmitting passwords over the network. The process involves obtaining a Ticket Granting Ticket (TGT) and subsequently service tickets to access resources. In the CompTIA Security+ (SY0-701) syllabus, Kerberos is highlighted as the default authentication protocol in Windows domains, offering mutual authentication and single sign-on (SSO) support. The mention of 'tickets' and 'Active Directory' points directly to Kerberos.

✗ **Why the others are wrong:**

- **RADIUS:** RADIUS (Remote Authentication Dial-In User Service) is an authentication, authorization, and accounting (AAA) protocol used primarily for remote network access, such as VPNs, corporate Wi-Fi, and dial-up connections. It does not use tickets; instead, it employs a client-server model with attributes and challenges (such as PAP, CHAP, EAP). Although it can integrate with Active Directory to validate credentials, it is not the native AD authentication protocol and is not ticket-based. Therefore, it does not match the description.

- **TACACS+:** TACACS+ (Terminal Access Controller Access-Control System Plus) is an AAA protocol developed by Cisco, used for authentication, authorization, and accounting of network devices (routers, switches). It separates AAA functions and encrypts the entire payload, but does not use tickets and is not the default authentication mechanism for Active Directory. Its focus is managing access to infrastructure equipment, not authenticating users in Windows domains. Thus, it is incorrect for the presented context.

- **LDAP:** LDAP (Lightweight Directory Access Protocol) is a protocol for accessing directory services, such as Active Directory, allowing queries and modifications to objects (users, groups, computers). It is used for reading and writing to the directory, but is not a ticket-based authentication protocol. Authentication in AD typically occurs via Kerberos or NTLM; LDAP can be used for simple authentication (bind), but does not employ tickets and is not the primary authentication mechanism in AD environments. Therefore, it does not meet the 'uses tickets' description.

4) B — Implement the corresponding solution: RBAC by ROLE; ABAC by attribute — the two ways to authorize....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management): RBAC by ROLE; ABAC by attribute — the two ways to authorize. Role-Based Access Control (RBAC) grants permissions based on the user's role within the organization, while Attribute-Based Access Control (ABAC) grants permissions based on a combination of attributes (user, resource, environment). These are the two primary authorization models.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput.* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: SSO: single login — reduces password reuse (more secure)..

The correct answer is to implement the corresponding solution: deploy Single Sign-On (SSO). According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management), SSO allows users to authenticate once and access multiple systems, which reduces password fatigue and the likelihood of password reuse, thereby improving overall security posture when combined with strong authentication. Distractor breakdown: • Temporarily disable audit logs to accelerate system throughput: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • Replace preventive technical controls with informal terms of adherence: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • Allow shared access among administrators using generic credentials: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'access assigned based on job role'=RBAC....

✓ **Why it is correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC. Role-Based Access Control (RBAC) assigns permissions based on the user's job function, enforcing least privilege and simplifying administration.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: 'marketing employee only accesses marketing department files' = RBAC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management): 'marketing employee only accesses marketing department files' = RBAC. Role-Based Access Control (RBAC) assigns permissions based on job roles, ensuring users have only the access necessary to perform their duties. This enforces least privilege and simplifies administration by grouping permissions into roles rather than assigning them to individual users.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: RBAC by ROLE; ABAC by attribute — the two ways to authorize....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management): RBAC by ROLE; ABAC by attribute — the two ways to authorize.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: SSO: single login — reduces password reuse (more secure)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management): SSO (Single Sign-On) allows users to authenticate once and access multiple applications, reducing password fatigue and the likelihood of password reuse, thereby improving security.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: 'access assigned based on job role'=RBAC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.